

Industry Standards & Methodology Frameworks

These standard bodies provide the structured methodologies used to evaluate, prioritize, execute, and audit portfolio projects.

- **PMI Standard for Portfolio Management (Project Management Institute):** Establishes the lifecycle for alignment, governance, risk management, and performance reporting across portfolios.
- **COBIT (Control Objectives for Information and Related Technologies):** Guides IT project portfolio governance, value optimization, resource management, and alignment with enterprise business objectives.
- **ITIL 4 (IT Service Management):** Ensures project portfolio deliverables transition smoothly into operational service delivery (Change Enablement, Service Portfolio Management).
- **ISO/IEC 27001 & ISO 31000:** International standards governing information security controls and general risk management protocols across project life cycles.

Regulatory Mandates & External Requirements

Because insurance companies hold fiduciary duties, issue regulated products, and process high volumes of sensitive personal data, project portfolios must embed legal and regulatory compliance directly into stage-gate approvals.

Regulatory Framework	Core Requirements for Portfolio & Project Management
NAIC CGAD & ORSA (<i>Corporate Governance Annual Disclosure / Own Risk & Solvency Assessment</i>)	Regulates how major strategic initiatives impact overall capital solvency, risk appetite, and executive board oversight.
Sarbanes-Oxley Act (SOX Section 404)	Applies to publicly traded insurers. Portfolio systems, financial software updates, and IT transformations must maintain strict internal controls over financial reporting (ICFR).
NYDFS Cyber Security (23 NYCRR 500) & NIST CSF	Mandatory cyber/privacy gates for any IT or software project. Requires security-by-design,

	vendor risk vetting, and multi-factor authentication (MFA) validation.
SEC Cybersecurity & Climate Disclosures	Requires projects driving digital transition or ESG metrics to have auditable logging and disclosure control mechanisms.
HIPAA / HITECH / State Privacy Laws (e.g., CCPA)	Ensures project deliverables handling claims or health data build strict data protection, access governance, and encryption safeguards.

Internal Governance Policies & Portfolio Controls

Internal policies operationalize external regulations into day-to-day Project Portfolio Management (PPM) practices.

- **Enterprise Risk Management (ERM) Alignment Policy:** Mandates that every proposed program or portfolio initiative receives an official risk score before funding approval to prevent over-concentration in high-risk ventures.
- **Capital Allocation & Investment Governance Policy:** Dictates capital budget authorization tiers, ROI target metrics, stage-gate funding releases, and quarterly portfolio re-balancing protocols.
- **Architecture Review Board (ARB) Policy:** Enforces Enterprise Architecture (EA) standards, prohibiting unauthorized tech stacks, legacy technical debt accumulation, or shadow IT applications.
- **Third-Party Risk Management (TPRM) Policy:** Governs vendor selection, software licensing, contractor engagements, and cloud software integrations within project pipelines.
- **Change Management & Quality Assurance (QA) Policy:** Establishes segregation of duties between project developers and production environments, mandatory testing protocols, and formal deployment approvals.